ANEXO-Comprobadores-de-integridad_1

Unidad N° 1: Introducción a la Seguridad

OpenSSL

¿Qué es OpenSSL?

OpenSSL es un conjunto de herramientas que se usa para:

- Cifrar y descifrar datos (criptografía).
- Hacer comunicaciones seguras (como HTTPS en los navegadores).
- Generar y verificar firmas digitales, certificados SSL, y más.

¿Para qué se usa en general?

- Crear conexiones seguras (HTTPS).
- Generar certificados digitales.
- Calcular valores de hash o digest (que sirven para verificar la integridad de datos).
  Probar o usar distintos algoritmos de cifrado y firma.

¿Qué es un Hash?

Un hash es como una “huella digital” de un archivo o texto. Si el contenido cambia,el hash también cambia.

Sirve para:

- Verificar si un archivo fue modificado.
- Comparar contraseñas sin guardarlas directamente.
- Validar integridad de archivos descargados.

Salt:Es un valor aleatorio que se añade a un dato (por ejemplo una contraseña) antes de calcular su hash.

Sirve para:

- Hacer que incluso dos usuarios con la misma contraseña tengan hashes diferentes.

- Evitar ataques como **tablas rainbow** o intentos de adivinar contraseñas precomputadas.
- Guardarse junto con el hash y utilizarse al verificar la contraseña.

Ejemplo:
Contraseña: MiClave123
Salt: A7f9G2
Hash calculado: hash(MiClave123 + A7f9G2) → valor único Incluso si otra persona tiene la misma contraseña `MiClave123`, el hash será distinto porque el salt es diferente.

Función de Hash: Se define como una función o método no reversible para generar un valor que represente de manera casi unívoca a un dato.

¿Qué son los algoritmos de hash?

Son los métodos para crear esos valores de hash. Algunos ejemplos son:

- `md5`, `sha256`, `sha3-512`, etc. Cada uno tiene diferentes niveles de seguridad y longitud del resultado.

¿Cómo se usa OpenSSL para calcular un hash?

Desde la consola o terminal, podés escribir algo como:

bash: `openssl sha3-256 -hex archivo.txt`

Eso te va a dar el valor de hash del archivo `archivo.txt` usando el algoritmo `sha3-256`, en formato hexadecimal.

HashDeep / md5deep

Hashdeep es un programa **Open Source** para calcular, verificar,y auditar hashsets. Con la comprobación tradicional, los programas informan si un archivo de entrada coincide con uno previamente registrado o no. Es difícil tener una idea completa de la situación de los archivos de entrada en comparación con el conjunto de datos conocidos. En este contexto es posible tener archivos emparejados, archivos que faltan, archivos que se han movido en el conjunto, y encontrar nuevos archivos en el conjunto. Hashdeep puede informar de todas estas condiciones.

¿Qué es HashDeep / md5deep?

HashDeep (y su versión más conocida md5deep) es una herramienta de código abierto que sirve para:

- Calcular hashes de archivos.
- Verificar si los archivos fueron modificados o si coinciden con un conjunto conocido.
- Auditar archivos comparándolos con una lista previa de hashes.
- Detectar archivos nuevos,faltantes o movidos.

📌*Es como un detector de cambios o manipulaciones en archivos. Muy útil en seguridad informática y análisis forense.*

¿Para qué se usa?

- Crear un registro (lista) de archivos y sus hashes.
- Verificar después si esos archivos siguen iguales o fueron modificados.
- Detectar archivos nuevos, faltantes, o movidos.

Por ejemplo:

- Te bajás una carpeta de archivos de una página y luego querés saber si alguien los cambió.

- O tenés un backup y querés validar si sigue siendo idéntico al original.

¿Qué diferencia hay entre HashDeep y md5deep?

- `md5deep` fue el nombre original del proyecto.
- `hashdeep` es una versión más moderna que soporta **más algoritmos de hash**, no solo MD5.

Algoritmos que soporta:

Podés usar varios algoritmos, por ejemplo:

- `md5`, `sha1`, `sha256`, `tiger`, `whirlpool`

🛠️ Instalación

Desde código fuente:

1. **Descargar**: desde la página oficial.
2. **Descomprimir:** tar zxvf md5deep-4.1.tar.gz
3. **Entrar a la carpeta:** cd md5deep-4.1
4. **configurar:** ./configure --prefix=/tmp/md5deep
5. **Compilar e instalar:** make install

En Linux:

(Ubuntu/Debian):bash `sudo apt-get install md5deep`

En Windows:

- Descargar los binarios precompilados desde la página oficial.
- Descomprimir la carpeta con los ejecutables.

⚙️ Opciones principales

Opción	Función
`-a`	Modo auditoría: compara con lista de hashes (requiere `-k`).
`-m`	Modo coincidencia: busca archivos que coinciden con la lista (requiere `-k`).
`-x`	Coincidencia negativa: muestra los que **no** coinciden (requiere `-k`).
`-w`	En `-m`, muestra qué archivos conocidos coinciden.
`-k archivo`	Usa una lista de hashes conocida.
`-r`	Recursivo: analiza subdirectorios.
`-e`	Estima tiempo de proceso.
`-v`	Verborrágico: muestra más información.

🧪 Opciones adicionales

Opción	Función
`-c alg1,alg2`	Elegir algoritmos: `md5`, `sha1`, `sha256`, `tiger`, `whirlpool`.
`-l`	Usa rutas relativas.
`-p`	Fracciona archivos para hashing.
`-i`	Procesa solo archivos **menores** a un límite.
`-o`	Procesa solo archivos de un **tipo específico**.

Tripwire

🔐 ¿Qué es Tripwire?

Tripwire es una herramienta open source que sirve para controlar la integridad de los archivos del sistema.
📌 **¿Qué significa esto?** Que detecta si algún archivo fue cambiado, eliminado o agregado sin autorización.

💡 ¿Cómo lo hace?

- Guarda una base de datos con "firmas" (hashes) de todos los archivos importantes.
- Luego, compara periódicamente el estado actual del sistema con esa base de datos para detectar cambios.

📍 *Solo funciona bien si se instala en un sistema limpio (sin malware), antes de conectarlo a internet.*

🛠️ Instalación

📌 En Ubuntu / Debian:

sudo apt-get install tripwire

📌 En Red Hat (Fedora, CentOS):

1. Descargar desde la web oficial.
2. Descomprimir:tar xvzf tripwire.tar.gz
3. Instalar:rpm -ivh tripwire-2.3-47.i386.rpm
4. Crear claves:/etc/tripwire/twinstall.sh

Política de Tripwire

🔑 **¿Qué es la política?** Es un archivo que define qué archivos se van a controlar, y cómo.

Pasos para configurar una política:

1. Ir al directorio de configuración:cd /etc/tripwire
2. Editar el archivo de política:vi twpol.txt
3. Compilar la política para que se aplique:twadmin --create-polfile --cfgfile ./tw.cfg --site-keyfile ./site.key ./twpol.txt

Tripwire - Envío de mails(Opcional)

Podés configurar la política para que envíe mails cuando detecta cambios, agregando una línea especial en la cabecera de las reglas del archivo de política.

Inicialización de la base:

Una vez definida la política, hay que generar la "foto inicial" del sistema para comparar en el futuro:

tripwire --init --cfgfile /etc/tripwire/tw.cfg --polfile /etc/tripwire/tw.pol --site-keyfile /etc/tripwire/site.key --local-keyfile /etc/tripwire/HOSTNAME-local.key

Verificación del sistema (chequeo de integridad):

Se puede ejecutar Tripwire para verificar si hubo cambios no autorizados en los archivos:

tripwire --check

El reporte se guarda en:

/var/lib/tripwire/report/

Ejemplo de cómo ver un reporte:

```
twprint -m r -r
/var/lib/tripwire/report/HOST-20250421-123456.twr
```

Actualizar la política:

Si necesitás cambiar la política (por ejemplo, agregar nuevas carpetas a monitorear), **usás estos comandos:**

tripwire --update-policy -v -Z low --cfgfile ./tw.cfg --polfile ./tw.pol --site-keyfile ./site.key --local-keyfile ./HOSTNAME-local.key ./twpol.txt

o tripwire -m p -Z low -v ./twpol.txt

¡IMPORTANTE!: Después de aplicar la política, eliminá los archivos `twcfg.txt` y `twpol.txt` porque contienen info sensible en texto plano:rm /etc/tripwire/twcfg.txt /etc/tripwire/twpol.txt

Actualizar la base de datos de hashes:

Cuando hacés cambios legítimos en el sistema (como actualizar programas), podés actualizar la base de datos con este comando:

tripwire --update -v -Z low -r /var/lib/tripwire/report/HOST-20250421-221053.twr

tripwire --update -v -Z low -r /var/lib/tripwire/report/HOST-20250421-221053.twr

o tripwire -m u -v -Z low -r /var/lib/tripwire/report/HOST-20250421-221053.twr

Consejo: hacé una verificación (`--check`) antes de actualizar, para evitar errores si falta un reporte.

Seguridad en sistemas informáticos: Todo sistema que procese, almacene o transmita información tiene que cumplir una serie de requisitos.

1) Ha de preservar la información frente a alteraciones tanto fortuitas como deliberadas, debidas a fallos en el software o en el hardware, provocadas por agentes externos —incendios, interrupciones en el suministro eléctrico, etc. -- o por los propios usuarios.
2) En segundo lugar, es necesario evitar accesos no autorizados tanto al sistema como a su contenido.
3) El sistema debe garantizar que la información esté disponible cuando sea necesario

Estos tres requerimientos quedan recogidos en los conceptos de integridad, confidencialidad y disponibilidad de la información respectivamente, y son los que hacen que podamos considerar seguro a un sistema.

Por lo tanto, garantizar la seguridad de un sistema informático es un objetivo mucho más amplio y complejo que la simple protección de los datos mediante técnicas criptográficas. De hecho, hemos de tener en cuenta múltiples factores, tanto internos como externos.

Tipos de Sistemas según su conexión a redes:

1. Sistemas aislados: No tienen conexión a redes. Son muy pocos hoy en día. Su seguridad depende de controles físicos (cerraduras, cámaras) y del manejo correcto de los privilegios de los usuarios.
2. Sistemas interconectados: Son los más comunes. Están conectados a redes constantemente (como computadoras, celulares o consolas). Esto hace que la gestión de la seguridad sea más compleja y desafiante.

Principales aspectos de la seguridad en sistemas informáticos:

- Seguridad física:
  Protege los soportes físicos de la información (no la info en sí). Incluye:
  - Prevención de incendios y fallos eléctricos.
  - Medidas contra ataques físicos o terroristas.
  - Backups y control de acceso físico a los equipos.
- Seguridad en canales de comunicación: Los canales no suelen ser seguros, ya que están fuera de nuestro control. Por eso se deben aplicar mecanismos de protección, incluso en entornos hostiles o manipulados.
- Control de acceso a los datos:

  Solo los usuarios autorizados deben acceder a la información

  Esto requiere:
  - Asignar privilegios individualizados.
  - Usar técnicas como el cifrado para proteger datos, incluso si alguien accede físicamente al dispositivo.
- Autenticación:

  Es necesario verificar la identidad:
  - De los usuarios.
  - De los dispositivos.
  - De la información transmitida.
    El objetivo es evitar suplantaciones de identidad.
- No repudio: Garantiza que el emisor de un mensaje no pueda negar su autoría, lo cual es vital en contratos y transacciones.
- Anonimato: Permite proteger la identidad de los usuarios en situaciones sensibles (como votaciones o denuncias).
  ⚠️ Aunque también puede usarse para actividades ilegales, lo que genera debates y dificultades para implementarlo en la industria.

Introducción a la seguridad 2

Información:
Es un grupo de datos ya procesados y ordenados,que sirven para construir un mensaje que cambia el estado de conocimiento del sujeto o sistema que lo recibe. La palabra información deriva del latin que significa “dar forma mente”,”disciplinar”,instruir ","enseñar ".

Característica de la información

Crítica: Es indispensable para la operación de la organización.

Valiosa: Es un activo apreciado por la organización y sus operaciones.

Sensitiva: Debe de ser conocida por las personas autorizadas.

Triangulo ID

Es el triángulo de la seguridad de la información, formado por:

Confidencialidad: Solo usuarios autorizados acceden a la información.

Integridad: Los datos no deben ser alterados de forma no autorizada.

Disponibilidad: La información debe estar accesible cuando se necesite.

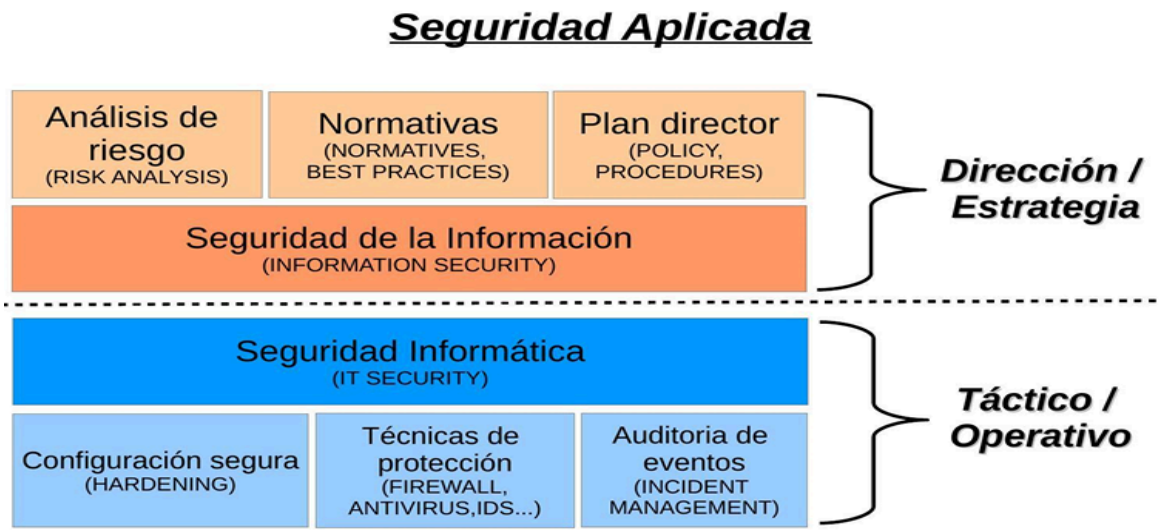
Definiciones

Seguridad: Proviene del latin securitas que deriva cuidado,sin precaución,sin temor a preocuparse qué significa libre de cualquier peligro o daño.
Se considera como un estado mental que produce en los individuos un particular sentimiento de que se está fuera o alejado de todo peligro ante cualquier circunstancia.

Seguridad de la información: Es la disciplina que nos habla de los riesgos,de las amenazas,de los análisis de escenarios,de las buenas prácticas y esquemas normativos,que nos exigen niveles de aseguramiento de procesos y tecnologías

para elevar el nivel de confianza en la creación,uso,almacenamiento,transmisión,recuperación y disposición final de la información.

Seguridad informática: Se encarga de las implementaciones técnicas de la protección de la información ,el despliegue de las tecnologías antivirus,firewalls ,detección de intrusos,detección de anomalías,correlación de eventos ,atención de incidentes,entre otros elementos,que articulados con prácticas del gobierno de tecnologia de informacion,establecen la forma de actuar y asegurar las situaciones fallas parciales o totales,cuando la información es el activo que se encuentra en riesgo.



Seguridad de la información

Política de seguridad: Son las decisiones o medidas de seguridad que una empresa ha decidido tomar respecto a la seguridad de sus sistemas de información después de evaluar el valor de sus activos y los riesgos a los que están expuestos.Este término también se refiere al documento de nivel ejecutivo mediante el cual una empresa establece sus directrices de seguridad de la información.

Plan director de seguridad: Proyecto consistente en la definición y priorización de una conjunto de medidas en materia de seguridad de la información con el objetivo de reducir los riesgos a los que está expuesta la organización hasta unos niveles aceptables.

Análisis de riesgos: Es un proceso que comprende la identificación de activos de información,sus vulnerabilidades y las amenazas a los que se encuentran expuestos

,así como la probabilidad de ocurrencia y el impacto de las misma,a fin de determinar los controles adecuados para tratar el riesgo.

Incidentes de seguridad

Son violaciones de seguridad que ocasionan destrucción acceso no autorizado,pérdida o alteración de datos personales cuando están siendo transmitidos están almacenados o son objeto de otros tratamientos.

Origen de los incidente:

- Accidente
- Interno(miembros de la organización)
- **Ciberataque:**Intento deliberado de obtener acceso a un sistema informático sin autorización en base al uso de diferentes técnicas y vulnerabilidades para la realización de actividades con fines maliciosos,como el robo de información,extorsión del propietario o simplemente daños al sistema.
- **Intrusión:** Acción provocada por un atacante o usuario malintencionado, que se aprovecha de una vulnerabilidad en el sistema para conseguir acceder a un área o dispositivo sin autorización con el objetivo de realizar actividades ilegítimas.
- **Términos relevantes:**riesgo,amenaza,no repudio,vulnerabilidades y anonimato.

Las causas de la inseguridad

Estado de inseguridad activo: La falta de conocimiento del usuario acerca de las funciones del sistema,algunas de las cuales pueden ser dañinas para la seguridad del mismo.Este estado se encuentra directamente relacionado con la acción humana que genera al sistema una condición que puede ser utilizada por un atacante para generar un daño.

- Activar servicios de red que el usuario no necesita.
- Abrir un archivo adjunto malicioso.
- Proporcionar información confidencial

Estado de inseguridad pasivo: La falta de conocimiento de las medidas de seguridad disponibles.Este escenario no está vinculado a la actividad humana,sino que está constituido por condiciones preexistentes que pueden ser utilizadas por un atacante para generar un daño.

- Cuando el administrador o usuario de un sistema no conocen los dispositivos de seguridad con los que cuentan.
- Errores en el código de un programa.
- Permisos incorrectos o configuración desactualizada de un sistema.
- Defectos de hardware.

Requisitos funcionales para la seguridad

- **Auditoría de seguridad:** Registro de actividades.
- **Soporte de cifrado:** Uso de criptografía para la protección de datos.
- Gestión de seguridad:gestión de perfiles de usuario y niveles de acceso vinculados a los mismos.
- **Privacidad:** Soporte del anonimato de los usuarios.
- **Autodefensa:** Controles para fallar de manera contenida o prevista.
- **Control de acceso:** Manejo de la cantidad y tiempo de las sesiones,concurrencia e información sobre sesiones previas.
- **Rutas o canales fiables:** Mecanismos que permitan confiar en los recursos accedidos como los certificados.

Seguridad lógica

Consiste en la aplicación de barreras y procedimientos que resguarden el acceso a los datos y solo se permita acceder a ellos a las personas autorizadas para hacerlo.

- Controles de acceso
- Identificacion y autenticacion
- Roles
- Transacciones
- Limitaciones a los servicios
- Modalidad de acceso
- Ubicación y horario
- **Control de acceso interno:**
    - ☐ Palabras claves(Passwords)
    - ☐ Cifrado
    - ☐ Listas de control de accesos
    - ☐ Límites sobre la interfaz de usuario
    - ☐ Etiquetas de seguridad(Consiste en designaciones otorgadas a los recursos (como por ejemplo un archivo)

- **Control de acceso externo:**
    - ☐ Dispositivos de control de puertos

- ☐ Firewalls o puertas de seguridad:
    - ☐ Son dispositivos de defensa perimetral que separan redes.
    - ☐ Filtran el tráfico dependiendo de reglas predefinidas. No protegen de ataques internos.
    - ☐ No protegen de accesos no autorizados.
    - ☐ No protegen de la totalidad de ataques dañinos.
- ☐ Acceso de personal contratado o consultores
- ☐ Acceso públicos

- **Administración:**
    - ☐ Administración del personal y usuario
    - ☐ Organización del personal

DMZ (Zona Desmilitarizada): Es un área de configuración del firewall con reglas específicas orientada a manejar equipos que deben tener mayor exposición en la infraestructura,osea es una subred aislada dentro de una red corporativa que se coloca entre la red interna (privada) y la red externa (Internet). como por ejemplo los servidores Web, de Correo y otros.

Prácticas de seguridad lógica en móviles

- Usar contraseñas robustas y bloqueo automático.
- Realizar copias de seguridad periódicas.
- Instalar software sólo de fuentes oficiales.
- Utilizar software solo con acceso legal a sus funcionalidades.
- Considerar el uso de software de seguimiento,borrado de datos y/o bloqueo remoto.
- Evitar o restringir conexiones a redes públicas o no confiables.
- Deshabilitar sistemas de bluetooth,NFC y otras tecnologías inalámbricas cuando no se requiera el uso de los mismos en dispositivos confiables.
- En dispositivos con conexión de datos móviles tener el PIN activado y su el PUK e IMEI memorizado

Rastreo y gestión remota de dispositivos

Este tipo de software permite realizar operaciones de forma remota sobre el equipo permitiendo el siguiente tipo de acciones:

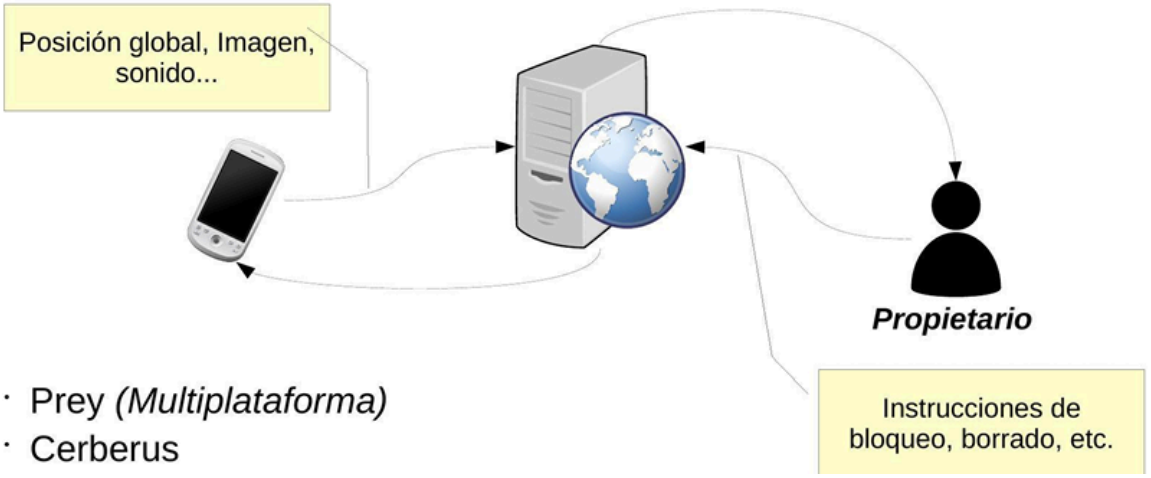
- Rastreo del dispositivo
- Borrado de datos
- Bloqueo del dispositivo

- Obtención de información del medio(grabación de audio ,video,etc).

Son aplicaciones particularmente útiles ante situaciones de pérdida y robo.
Su funcionalidad suele estar limitada por la conectividad del equipo.

Rastreo y gestión remota

- Prey(Multiplataforma)
- Cerberus
- Avast Anti-Theft
- Android(Ajustes / Seguridad/ Administradores del dispositivo)
- Iphone(¡Cloud.com/ Find My Iphone)



Copias de seguridad

Una política de copia de seguridad es un documento que define las reglas y procedimientos para la creación,almacenamiento y gestión de las copias de seguridad de datos en una organización.Esta debe ser revisada y actualizada periódicamente para asegurar que se ajusta a las necesidades de la organización.
La política definirá frecuencia y modalidad de las copias,**esto último puede ajustarse a los siguientes tipos:**

- Copia total:Hace una copia completa de todos los datos seleccionados, sin importar si cambiaron o no.
- Copia diferencial:Copia solo los archivos que cambiaron desde la **última copia total**.
- Copia incremental:Copia solo los archivos que cambiaron desde la **última copia (sea total o incremental)**.

Característica	🔁 Copia Incremental	📂 Copia Diferencial
Referencia	Desde la última copia (total o incremental)	Desde la última copia **total**
Tamaño	Pequeño (copia solo los cambios recientes)	Crece con el tiempo (acumula más cambios)
Velocidad de copia	Rápida	Más lenta que la incremental
Velocidad de restauración	Lenta (necesita muchas copias)	Rápida (solo necesitas total + última diferencial)
Ejemplo	Día 1: total Día 2: cambios desde Día 1 Día 3: cambios desde Día 2	Día 1: total Día 2: cambios desde Día 1 Día 3: cambios desde Día 1
Cantidad de archivos para restaurar	Copia total + todas las incrementales	Copia total + última diferencial
Uso recomendado	Cuando se prioriza ahorrar espacio	Cuando se prioriza facilidad de recuperación

La definición de la política y su ejecución debe considerar los siguientes puntos:

- Soporte de la copia(Cinta,discos,memorias,cloud,etc)
- Pruebas de restauraciones periódicas.
- Control de acceso a las copias
- Rotación de medios y período de retención
- Almacenamiento y traslados
- Eliminación y reutilización de soportes

Seguridad lógica

Estos son otros elementos comunes en el manejo de la seguridad de sistemas:

- **Firewalls:** Son dispositivos o software que filtran el tráfico de red.Funcionan como un "portero" entre una red confiable (como tu computadora o red interna) y una no confiable (como Internet).Bloquean o permiten paquetes de datos según reglas predefinidas.

- **Firewalls personales:** Son firewalls instalados en una sola computadora.Protegen el equipo del tráfico no autorizado o sospechoso.

- **Escáneres de vulnerabilidades:** Herramientas que analizan sistemas, redes o aplicaciones en busca de fallos de seguridad conocidos. Generan

reportes con las vulnerabilidades detectadas y posibles soluciones. Por ejemplo, pueden identificar formularios web vulnerables a inyección SQL o sitios expuestos a XSS (Cross-Site Scripting).

- **Honeypots:**Sistema trampa diseñado para atraer atacantes y analizar su comportamiento.

- **Honeynets:**Conjunto de honeypots conectados entre sí simulando una red real.

- **Padded cells:**Entorno seguro donde, una vez detectado, se traslada al atacante para monitorearlo sin riesgo al sistema real.

- **Verificadores de integridad:**Herramientas que monitorizan si archivos críticos han sido modificados.

- **IDS (Intrusion Detection System):**Sistema que detecta comportamientos anómalos o sospechosos en una red o sistema. No actúa automáticamente, solo avisa (genera alertas). Puede ser basado en firmas (como un antivirus) o en comportamiento.

- **IPS (Intrusion Protection System):**Similar al IDS, pero va un paso más allá: no solo detecta, también bloquea el tráfico malicioso en tiempo real.Actúa como defensa activa. Suele ir integrado con firewalls o sistemas de red.
- **Antivirus:**Programa que detecta, bloquea y elimina malware como virus, gusanos, troyanos, etc. Funciona principalmente a través de bases de firmas y análisis heurístico. Se enfoca en el nivel de archivos y procesos.

- **WAF(Web Application Firewall):** Es un tipo de firewall que protege las aplicaciones web filtrando, monitoreando y bloqueando tráfico HTTP(S) malicioso hacia y desde una aplicación web. Su función principal es prevenir ataques comunes como Inyección SQL,Cross-Site Scripting (XSS),Cross-Site Request Forgery (CSRF),Fuerza bruta,File inclusion.

Referencia VPN

Una estructura de red que con soporte lógico que permite el tráfico de información privada sobre una infraestructura de red pública mediante el uso de criptografía.

Protocolos:

- IPSec
- SSL/TLS
- PPTP,L2TP

Seguridad física

Tipo de desastres:

- Desastres naturales,incendios accidentales, tormentas e inundaciones.
- Disturbios,sabotajes internos y externos deliberados.
- Amenazas ocasionadas por el nombre.

Acciones hostiles:

- Robo
- Fraude
- Sabotaje

Control de accesos:

- Utilizacion de guardias
- Utilización de detectores metales
- Utilización de **sistemas biométricos:** Tecnología que identifica personas mediante características físicas únicas (huellas, ojos, voz, etc.) comparándolas con patrones almacenados en una base de datos.
- Verificación automática de firmas(VAF)
- Seguridad con animales
- Protección electrónica

Practicas de seguridad fisica en moviles

- Evitar o restringir la manipulación del dispositivo en zonas públicas.
- No transportar el dispositivo en contenedores que puedan ser visibles a terceros .
- Utilizar contenedores de transporte que reduzcan la fuerza ante impactos.
- Utilizar contenedores de transporte que protejan al dispositivo del contacto con líquidos.

Impacto en la organización

- Pérdida de datos: Puede afectar la reputación,la productividad y la rentabilidad de la organización.
- Robo de identidad: Puede afectar a los clientes y empleados de la organización.
- Interrupción del negocio: Puede causar daños económicos y afectar la imagen de la organización.

- Daño a la reputación: Puede afectar la confianza de los clientes y socios de la organización.

Factores a considerar en el impacto de la seguridad en la organización y sus procesos:

- Cambios en lo que respecta a los riesgos para la seguridad a través del tiempo.
- Políticas de seguridad corporativa.
- Evaluación y tratamiento del riesgo.
- Políticas de control de accesos.
- Gestión de la continuidad del negocio.
- Procedimientos de cumplimiento y de las operaciones.
- Manejo de las comunicaciones y de las operaciones.
- Administración de los incidentes en seguridad de la información.
- Protocolos para la gestión de los activos.
- Adquisición,desarrollo y mantenimiento de los sistemas de información.
- Seguridad física y ambiental.
- Organización de la seguridad de la información.
- Integración de la seguridad de la información.